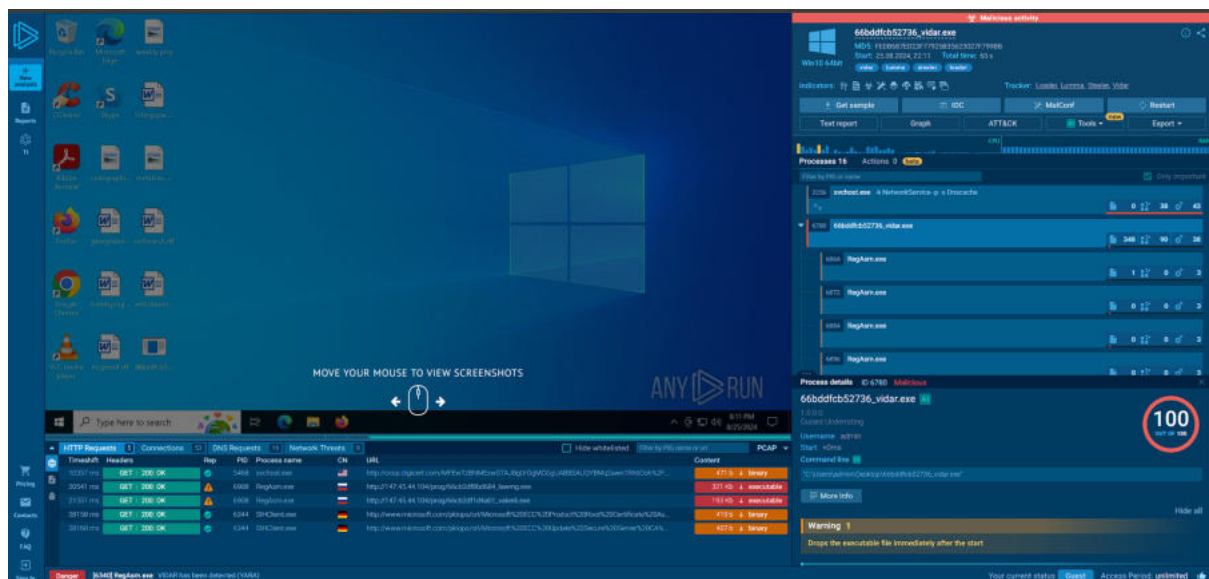


Report Analisi Minacce Any.Run

Dettaglio Tecnico: Campione Malevolo 1

Di seguito degli eventi malevoli ricostruiti dall'analisi dinamica:



Fase 1: Infezione

Il malware identificato come Vidar/Lumma si maschera iniettando codice all'interno del processo legittimo di Windows **RegAsm.exe** (Microsoft .NET Assembly Registration Utility) per eludere i controlli antivirus di base.

Per non lasciare tracce forensi, il malware ha continua l'attacco invocando il processo di sistema **conhost.exe** con il parametro **0xffffffff -ForceV1**, una tecnica per gestire l'esecuzione della console in modo nascosto.

Il malware avvia più processi **RegAsm.exe** che lavorando in asincrono svolgono tutte le mansioni più velocemente e silenziosamente possibile

Subito dopo l'avvio, il processo infetto rilascia librerie di supporto (DLL

come:msvcp140.dll,mzglue.dll,vcruntime140.dll,nss3.dll,softoken3.dll,freebl3.dll) necessarie per eseguire i suoi moduli di furto dati.

Oltre alle librerie, il processo malevolo dropa dei file eseguibili per aiutarlo nel furto di dati e nell'auto cancellazione a processo compiuto.

C:\ProgramData\CAFHDBGHJK.exe

C:\Users\admin\AppData\Local\Microsoft\Windows\INetCache\IE\E4DJRUXW\66cb2df1d4a01_vakerk[1].exe

C:\Users\admin\AppData\Local\Microsoft\Windows\INetCache\IE\E4DJRUXW\66cb2df8bd684_lawrng[1].exe

C:\ProgramData\CAFHDBGHJK.exe

Fase 2: Furto di Dati

Il malware ha eseguito operazioni di lettura non autorizzate su file sensibili:

Browser: Ha acceduto al file **Local State** di **Google Chrome**, **Microsoft Edge**, al file **LastVersion** di **Opera** e al file **Userdata** di **Amigo** per decifrare le password e i cookie salvati.

FTP: Ha sottratto le credenziali dei server dal file di configurazione **recentservers.xml** di **FileZilla**.

Dal file **profiles.ini** del browser Pale Moon e del servizio Thunderbird

Ricognizione: Ha raccolto informazioni sull'hardware, sul nome del computer, su tutti i programmi installati, sulle impostazioni di sicurezza dei vari browser e sulla data di installazione di Windows per profilare la vittima.

Fase 3: Esfiltrazione e Connessioni C2

I dati raccolti sono stati inviati a server di comando e controllo. Sono state rilevate connessioni verso indirizzi IP malevoli come **147.45.44.104** e **172.67.215.62**.

Fase 4: Evasione e Auto-Cancellazione

Il processo **RegAsm.exe** infine crea un file temporaneo specifico nel percorso **C:\Users\admin\AppData\Local\Temp\delays.tmp**. Questo file serve spesso al malware per gestire i tempi di connessione o come marker dell'infezione.

Per non lasciare tracce forensi, il malware ha concluso l'attacco invocando di nuovo il processo di sistema **conhost.exe** con il parametro **0xffffffff -ForceV1**.

Lanciato un comando **cmd.exe** concatenato:

timeout /t 10: Attesa di 10 secondi

rd /s /q "C:\ProgramData\FHJDBKJKFIEC"& exit:
Cancellazione forzata e silenziosa della cartella del malware in **ProgramData**.

Piano di Remediation

Per il Campione 1 (Vidar/Lumma):

Classificazione: Vero Positivo.

Azione Immediata: Isolamento della macchina dalla rete.

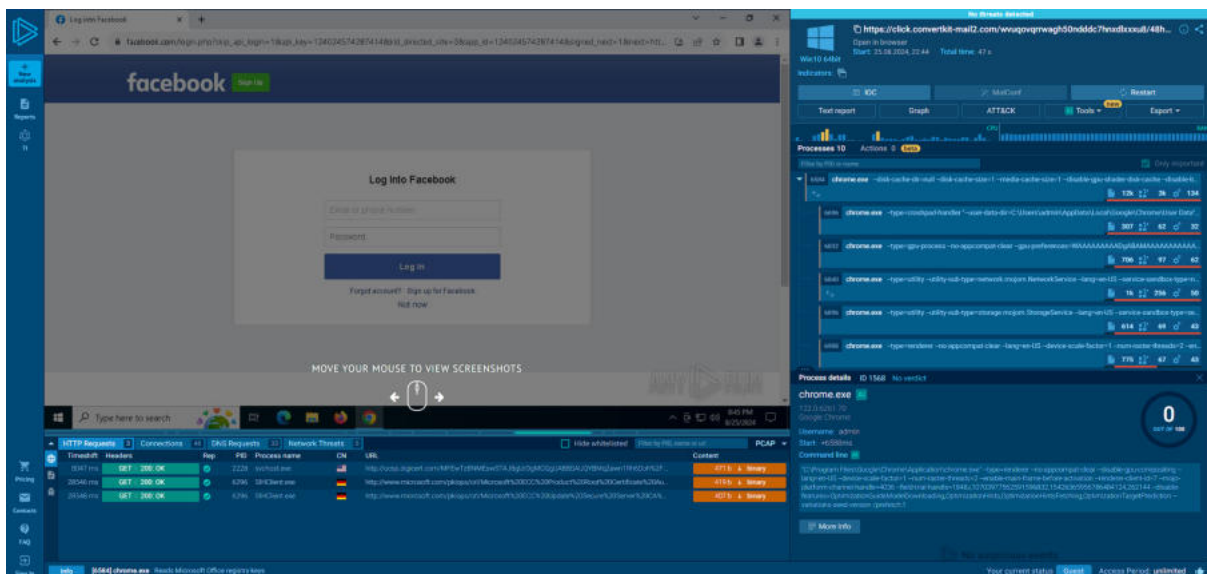
Tutte le credenziali (Web, FTP, Email) usate sulla macchina infetta sono da considerarsi compromesse e devono essere cambiate da una postazione sicura.

Reinstallazione completa del sistema operativo. La semplice rimozione dell'eseguibile non garantisce la pulizia data la manipolazione di processi di sistema come **RegAsm** e **conhost**.

Bloccare gli IP **147.45.44.104** e **172.67.215.62** sul Firewall perimetrale.

Per il Campione 2:

L'URL analizzato è stato classificato come **FALSO POSITIVO**.



Potrebbe sembrare un link sospetto a causa della sua lunghezza e complessità (**<https://click.convertkit-mail2.com/>**)

Ma l'esecuzione del link in ambiente controllato ha prodotto un esito di Nessuna minaccia rilevata. Il browser ha caricato legittimamente una pagina di login di Facebook/Instagram senza avviare download nascosti o script malevoli.

Il dominio **convertkit-mail2.com** appartiene a una nota piattaforma di **Email Marketing** legittima. Questi link vengono generati automaticamente per tracciare i click nelle newsletter promozionali.

La stringa finale dell'URL (codificata in Base64) è stata decodificata rivelando la destinazione reale e innocua: un profilo

pubblico di **Instagram**

(www.instagram.com/aussienurserecruiters).

Azione Raccomandata:

Nessuna azione di blocco necessaria.